IDX
Indonesia Stock Exchange
Bursa Efek Indonesia

AKU INVESTOR SAHAM

SURAT KEPUTUSAN DIREKSI PT BURSA EFEK INDONESIA

Nomor	:	Kep-00021/BEI/02-2026
Perihal	**:**	**Pedoman Fasilitas Pesanan Langsung dan *Automated Ordering***
Tgl. Dikeluarkan	:	10 Februari 2026
Tgl. Diberlakukan	:	10 Februari 2026

Menimbang :

a. bahwa sehubungan dengan perkembangan teknologi informasi yang terjadi saat ini maka diperlukan penyesuaian ketentuan dalam Pedoman Fasilitas Penyampaian Pesanan Langsung dan *Automated Ordering* yang terdapat di Bursa;

b. bahwa untuk meningkatkan keamanan sistem informasi atas perkembangan teknologi sebagaimana huruf a. di atas, Bursa melakukan penyesuaian atas keamanan sistem informasi, khususnya terkait *Multi-Factor Authentication*;

c. bahwa berdasarkan pertimbangan sebagaimana dimaksud dalam huruf a. dan b. di atas, dipandang perlu untuk menetapkan perubahan Pedoman Fasilitas Pesanan Langsung dan *Automated Ordering* dalam Keputusan Direksi PT Bursa Efek Indonesia.

Mengingat :

1. Undang-Undang Nomor 8 Tahun 1995 tentang Pasar Modal (Lembaran Negara Republik Indonesia Tahun 1995 Nomor 64, Tambahan Lembaran Negara Republik Indonesia Nomor 3608) sebagaimana telah diubah dengan Undang-Undang Nomor 4 Tahun 2023 tentang Pengembangan dan Penguatan Sektor Keuangan (Lembaran Negara Republik Indonesia Tahun 2023 Nomor 4, Tambahan Lembaran Negara Republik Indonesia Nomor 6845);

2. Undang-Undang Nomor 19 Tahun 2016 tentang Perubahan Atas Undang-Undang Nomor 11 Tahun 2008 Tentang Informasi Dan Transaksi Elektronik (Lembaran Negara Republik Indonesia Tahun 2016 Nomor 251, Tambahan Lembaran Negara Republik Indonesia Nomor 5952);

3. Undang-Undang Nomor 11 Tahun 2008 tentang Informasi dan Transaksi Elektronik (Lembaran Negara Republik Indonesia Tahun 2008 Nomor 58, Tambahan Lembaran Negara Republik Indonesia Nomor 4843);

4. Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik (Lembaran Negara Republik Indonesia Tahun 2019 Nomor 185, Tambahan Lembaran Negara Republik Indonesia Nomor 6400);

5. Peraturan Menteri Komunikasi dan Informatika Republik Indonesia Nomor 20 Tahun 2016 tentang Perlindungan Data Pribadi Dalam Sistem Elektronik (Berita Negara Republik Indonesia Tahun 2016 Nomor 1829);

6. Peraturan Otoritas Jasa Keuangan Nomor 3/POJK.04/2021 tentang Penyelenggaraan Kegiatan Di Bidang Pasar Modal (Lembaran Negara Republik Indonesia Tahun 2021 Nomor 71, Tambahan Lembaran Negara Republik Indonesia Nomor 6663);

7. Peraturan Otoritas Jasa Keuangan Nomor 21/POJK.04/2021 tentang Mitra Pemasaran Perantara Pedagang Efek (Lembaran Negara Republik Indonesia Tahun 2021 Nomor 259, Tambahan Lembaran Negara Republik Indonesia Nomor 6739);

8. Peraturan Otoritas Jasa Keuangan Nomor 13 Tahun 2025 tentang Pengendalian Internal dan Perilaku Perusahaan Efek yang Melakukan Kegiatan Usaha Sebagai Penjamin Emisi Efek dan Perantara Pedagang Efek (Lembaran Negara Republik Indonesia Tahun 2025 Nomor 21/OJK, Tambahan Lembaran Negara Republik Indonesia Nomor 151/OJK);

9. Peraturan Nomor III-K tentang Fasilitas Pesanan Langsung Dan/Atau Penerapan *Automated Ordering* Oleh Anggota Bursa Efek (Lampiran Keputusan Direksi PT Bursa Efek Indonesia Nomor: Kep-00010/BEI/02-2022 tanggal 9 Februari 2022 perihal Peraturan Nomor III-K tentang Fasilitas Pesanan Langsung Dan/Atau Penerapan *Automated Ordering* Oleh Anggota Bursa Efek).

MEMUTUSKAN:

Menetapkan :

1. Pedoman Fasilitas Pesanan Langsung dan *Automated Ordering*, sebagaimana dimuat dalam Lampiran Keputusan ini.

2. Bagi Anggota Bursa Efek yang telah memiliki Surat Persetujuan untuk menyediakan Fasilitas Pesanan Langsung dan/atau Penerapan *Automated Ordering* sebelum tanggal diberlakukannya keputusan ini, diberikan waktu untuk melakukan penyesuaian sebagaimana pada Bab III angka 2, 3, 5, 7, 8, 9, 10, 11, 12, dan 18 paling lambat pada tanggal 30 Desember 2026.

3. Dengan diberlakukannya Keputusan ini, maka Surat Keputusan Direksi PT Bursa Efek Indonesia Nomor: Kep-00084/BEI/12-2025 tanggal 17 Desember 2025 perihal Pedoman Fasilitas Pesanan Langsung dan *Automated Ordering*, dicabut dan dinyatakan tidak berlaku.

4. Keputusan ini efektif sejak tanggal diberlakukan.

Hormat kami,

Irvan Susandy
Direktur

Sunandar
Direktur

Tembusan:
1. Yth. Kepala Eksekutif Pengawas Inovasi Teknologi Sektor Keuangan, Aset Keuangan Digital, dan Aset Kripto sebagai pejabat sementara Kepala Eksekutif Pengawas Pasar Modal, Keuangan Derivatif, dan Bursa Karbon, Otoritas Jasa Keuangan, Republik Indonesia;
2. Yth. Deputi Komisioner Pengawas Pengelolaan Investasi Pasar Modal dan Lembaga Efek, Otoritas Jasa Keuangan;
3. Yth. Deputi Komisioner Pengawas Emiten, Transaksi Efek dan Pemeriksaan Khusus, Otoritas Jasa Keuangan;
4. Yth. Kepala Departemen Pengawasan Lembaga Efek, Otoritas Jasa Keuangan;
5. Yth. Kepala Departemen Pemeriksaan Khusus, Pengawasan Keuangan Derivatif, Bursa Karbon dan Transaksi Efek, Otoritas Jasa Keuangan;
6. Yth. Kepala Direktorat Pengawasan Transaksi Efek, Otoritas Jasa Keuangan;
7. Yth. Kepala Direktorat Pengawasan Perusahaan Efek, Otoritas Jasa Keuangan;
8. Yth. Kepala Direktorat Pengawasan Lembaga Efek dan Lembaga Penunjang, Otoritas Jasa Keuangan;
9. Yth. Direksi PT Kliring Penjaminan Efek Indonesia;
10. Yth. Direksi PT Kustodian Sentral Efek Indonesia;
11. Yth. Dewan Komisaris PT Bursa Efek Indonesia.

LAMPIRAN
Keputusan Direksi PT Bursa Efek Indonesia
Nomor : Kep-00084/BEI/12-2025
Tanggal ditetapkan : 17 Desember 2025
Tanggal diberlakukan : 17 Desember 2025
Diubah dengan:
Keputusan Direksi PT Bursa Efek Indonesia
Nomor : Kep-00021/BEI/02-2026
Tanggal ditetapkan : 10 Februari 2026
Tanggal diberlakukan : 10 Februari 2026

PEDOMAN FASILITAS PESANAN LANGSUNG DAN *AUTOMATED ORDERING*

DAFTAR ISI

I.	PENDAHULUAN	1
II.	DEFINISI	1
III.	KETENTUAN BAGI ANGGOTA BURSA EFEK YANG MENYEDIAKAN FASILITAS PESANAN LANGSUNG	1
IV.	KETENTUAN TAMBAHAN BAGI ANGGOTA BURSA EFEK YANG MENYEDIAKAN FASILITAS PESANAN LANGSUNG DENGAN MELAKUKAN KERJASAMA LAYANAN ATAU MENGGUNAKAN JASA PIHAK LAIN	5
V.	KETENTUAN BAGI ANGGOTA BURSA EFEK YANG MENERAPKAN *AUTOMATED ORDERING*	7

I. PENDAHULUAN

Pedoman ini merupakan satu kesatuan dengan ketentuan yang ditetapkan dalam Peraturan Nomor III-K tentang Fasilitas Pesanan Langsung dan/atau Penerapan *Automated Ordering* oleh Anggota Bursa Efek yang harus dipenuhi oleh Anggota Bursa Efek yang menyediakan Fasilitas Pesanan Langsung dan/atau menerapkan *Automated Ordering*.

II. DEFINISI

Dalam Pedoman ini, yang dimaksud dengan:

1. **Anggota Bursa Efek** adalah Perantara Pedagang Efek yang telah memperoleh izin usaha dari Otoritas Jasa Keuangan dan telah memperoleh persetujuan keanggotaan Bursa untuk mempergunakan sistem dan/atau sarana Bursa dalam rangka melakukan kegiatan perdagangan Efek di Bursa sesuai dengan Peraturan Bursa.

2. ***Audit Trail*** adalah catatan kejadian secara urut waktu beserta data yang mendukung kejadian tersebut.

3. ***Automated Ordering*** adalah pesanan secara elektronik yang digunakan untuk pengambilan keputusan dalam mengeksekusi pesanan perdagangan Efek tanpa intervensi manusia untuk mencapai tujuan tertentu berdasarkan algoritma dan parameter yang telah ditetapkan antara lain volume, harga, instrumen, pasar, jenis, waktu, dan berita.

4. ***Brokerage Office System*** **(BOFIS)** adalah sistem Perusahaan Efek yang meliputi *front office* sampai dengan *back office* termasuk pengendalian risiko yang digunakan untuk mendukung pelaksanaan Remote Trading dan operasional sebagai Anggota Bursa Efek dan telah memperoleh pernyataan layak oleh Bursa.

5. **Fasilitas Pesanan Langsung** adalah fasilitas yang disediakan oleh Anggota Bursa Efek yang memungkinkan nasabah menyampaikan sendiri penawaran jual dan/atau permintaan beli Efek melalui BOFIS dan Perangkat Remote Trading Anggota Bursa Efek yang dilengkapi dengan validasi otomatis, untuk selanjutnya diteruskan ke JATS.

6. **Jakarta Automated Trading System (JATS)** adalah sistem perdagangan Efek yang berlaku di Bursa untuk perdagangan yang dilakukan secara otomasi dengan menggunakan sarana komputer.

7. **Waktu JATS** adalah waktu yang tertera pada JATS.

III. KETENTUAN BAGI ANGGOTA BURSA EFEK YANG MENYEDIAKAN FASILITAS PESANAN LANGSUNG

Anggota Bursa Efek yang menyediakan Fasilitas Pesanan Langsung wajib memenuhi persyaratan teknis terkait konsep utama keamanan sistem yang paling kurang meliputi hal-hal sebagai berikut:

1. Ketentuan mengenai implementasi keamanan (*security*).

   Memiliki tata kelola sistem keamanan Fasilitas Pesanan Langsung yang meliputi:

a. Kerahasiaan informasi (*confidentiality*) untuk memastikan informasi hanya dapat diakses oleh pihak yang berhak mendapatkannya;

b. Keutuhan informasi (*integrity*) untuk memastikan ketepatan (akurasi), konsistensi, dan validitas informasi; dan

c. Ketersediaan informasi (*availability*) untuk memastikan informasi dapat diakses oleh pihak yang berwenang setiap saat dibutuhkan.

2. Anggota Bursa Efek telah menerapkan Antivirus yang telah di-install pada seluruh perangkat aplikasi yang mendukung sistem perdagangan AB (*windows, linux*, atau lainnya) dengan ketentuan:

   a. Aplikasi Antivirus berlisensi dan *updated*; dan
   b. *Signature* Antivirus yang selalu diperbarui (*up to date*).

3. Pengendalian terhadap program-program berbahaya (*malicious code*), termasuk namun tidak terbatas pada penerapan pembaruan (*update*) berkala terhadap antivirus atau anti-*malware*, pembaruan sistem operasi, serta penerapan *patching*, termasuk penetapan frekuensi minimum pembaruan.

4. Pengelolaan informasi dan pengelolaan perangkat cadangan

   a. Melakukan aktivitas *back up* data dan Audit Trail setiap hari dengan tetap menjaga integritas dan keamanan datanya. Dengan memperhatikan ketentuan terkait klasifikasi data (Terbuka, Rahasia, dan Sangat Rahasia), penerapan *immutable backup* (termasuk lokasi penyimpanan data cadangan), serta enkripsi data secara menyeluruh terhadap data dan file konfigurasi, termasuk aspek kerahasiaan dan ketersediaan melalui redundansi dan *failover* sistem.

   b. Menyediakan sistem Fasilitas Pesanan Langsung di area *Disaster Recovery Center* (DRC) apabila lebih dari 50% (lima puluh perseratus) dari total nilai transaksi Anggota Bursa Efek berasal dari transaksi yang dilakukan melalui sistem Fasilitas Pesanan Langsung berdasarkan perhitungan nilai transaksi yang dilakukan oleh Bursa, dengan ketentuan:

      1) Anggota Bursa Efek melakukan evaluasi secara berkala setiap bulan Juli di tahun berjalan atas nilai transaksi. Dalam hal Anggota Bursa Efek transaksi melalui sistem *Online Trading* lebih dari 50% dari total nilai transaksi Anggota Bursa Efek, maka Anggota Bursa Efek wajib menyediakan sistem *Online Trading* di Area DRC pada tahun berikutnya;

      2) Apabila Anggota Bursa Efek memiliki sistem *Direct Market Access*, maka penyediaan sistem *Direct Market Access* di area DRC sesuai dengan kebutuhan *Business Impact Analysis* Anggota Bursa Efek;

      3) kewajiban untuk menyediakan sistem Fasilitas Pesanan Langsung di area DRC wajib dipenuhi oleh Anggota Bursa Efek paling lambat 1 (satu) tahun sejak Anggota Bursa Efek mengeluarkan hasil evaluasi sesuai klausula nomor 1 di atas;

      4) Bursa melakukan evaluasi secara berkala terhadap pemenuhan sistem transaksi Anggota Bursa Efek berasal dari transaksi yang dilakukan melalui sistem Fasilitas Pesanan Langsung di area DRC AB;

      5) Anggota Bursa Efek wajib untuk melakukan pengujian di area DRC secara rutin;

      6) Bursa berwenang untuk mengenakan sanksi atas pelanggaran pedoman ini.

c. Menyediakan peralatan pengganti untuk menggantikan peralatan yang rusak, baik disediakan sendiri oleh Anggota Bursa Efek maupun menggunakan jasa vendor melalui kontrak jasa pemeliharaan.

d. Guna menjaga kelangsungan operasi, Anggota Bursa Efek harus memiliki jaminan ketersediaan *source code* aplikasi yang digunakan, dengan ketentuan:

1) Memiliki prosedur tertentu, bagi Anggota Bursa Efek yang mengembangkan sendiri aplikasinya; atau

2) Bagi Anggota Bursa Efek yang aplikasinya dikembangkan oleh vendor, maka dapat memilih untuk:

i. Melakukan penyimpanan *source code* di *escrow agent*; atau

ii. Memiliki perjanjian dengan vendor yang paling kurang mengatur hal sebagai berikut:

a) Vendor wajib menjaga versi terakhir yang di-*install* di Anggota Bursa Efek; dan

b) Apabila vendor tidak bisa memberikan *support maintenance*, maka wajib menyerahkan *source code* ke Anggota Bursa Efek.

5. Menerapkan kriptografi dalam bentuk *secure channel* (data diacak dengan metode tertentu) sehingga dapat menutup kemungkinan pihak lain menyalahgunakan data yang dipertukarkan antara Anggota Bursa Efek dengan nasabah.

6. Menerapkan sistem pemantauan atau *monitoring* meliputi:

a. Memonitor dan menjaga ketersediaan setiap komponen sistem seperti aplikasi, *operating system*, *server,* perangkat keamanan, dan perangkat komunikasi dalam Fasilitas Pesanan Langsung.

b. Sentralisasi log (*syslog server*) untuk mengumpulkan dan menyimpan catatan aktivitas (*log activity*) di dalam sistem Fasilitas Pesanan Langsung.

c. Memiliki fungsi *Audit Trail* beserta data yang mendukung kejadian tersebut. Fungsi *Audit Trail* ini harus aktif setiap saat.

d. Memiliki mekanisme evaluasi *log* sistem terkait aktivitas nasabah untuk analisis insiden.

e. Data yang tercatat dalam *Audit Trail* paling kurang memuat waktu kejadian, IP Address, *User* ID, dan data mengenai kejadian.

f. Menghindari adanya fungsi untuk menonaktifkan *Audit Trail* kecuali hal tersebut tidak dapat dihindari, misalnya pada peralatan teknologi informasi yang merupakan produksi massal.

g. *Log-based alert* yang dapat memberikan notifikasi otomatis atas aktivitas yang mencurigakan dan/atau tidak biasa.

h. Apabila Anggota Bursa Efek memiliki *Security Information and Event Management* (SIEM), maka Anggota Bursa Efek dapat memanfaatkan SIEM dalam melakukan aktivitas analisis *log*.

i. Apabila Anggota Bursa Efek memiliki *AI-based real-time alert*, maka dapat memanfaatkan *AI-based real-time alert* tersebut untuk memantau anomali dalam proses operasional *order*.

7. Melakukan sinkronisasi waktu dengan Waktu JATS di setiap perangkat dan aplikasi yang digunakan dalam penyelenggaraan Fasilitas Pesanan Langsung paling kurang 1 (satu) kali setiap Hari Bursa sebelum waktu perdagangan.
8. Memiliki dan menjalankan sistem pemantauan yang dilakukan secara terus menerus untuk mendeteksi aktivitas yang mencurigakan atau tidak biasa.
9. Memiliki kebijakan terkait dengan *password* yang terimplementasi di Anggota Bursa Efek
10. Menerapkan *enforcement* kepada nasabah apabila nasabah belum melakukan konfigurasi atas *password* baru yang telah diberikan.
11. Kebijakan Pengendalian Akses dan Penggunaan *Password*.
    a. Autentikasi

       Aplikasi Fasilitas Pesanan Langsung hanya dapat diakses setelah proses autentikasi dilakukan melalui 2 (dua) tahap yaitu tahapan pertama untuk mengakses seluruh fungsi selain fungsi portofolio dan transaksional. Kemudian tahapan kedua untuk mengakses fungsi portofolio dan transaksional. Bentuk autentikasi yang wajib diterapkan seperti berikut:

       1) Tahap pertama menerapkan salah satu "*what you know*" (seperti PIN atau *password*), "*what you have*" (seperti identitas elektronik, kartu magnetis dengan chip, *one time password* (OTP), token, atau *digital signature*), atau "*what you are*" (*biometric* seperti sidik jari); dan

          Dalam hal pada tahapan pertama autentifikasi menggunakan metode *what you know (pin atau password),* maka wajib diterapkan *Multi-Factor Authentication* (MFA) dengan menggunakan metode autentifikasi *what you have (*seperti identitas elektronik, kartu magnetis dengan *chip, one time password (OTP),* token, atau *digital signature)* atau *what you are (biometrick,* seperti sidik jari*)*.

       2) Tahap kedua menerapkan metode autentikasi yang berbeda dari tahap pertama. Sebagai contoh apabila tahap pertama *what you know* maka tahap kedua *what you have* atau *what you are***.**

    b. Memastikan tidak terdapat fasilitas tertentu yang dapat mengakses sistem Fasilitas Pesanan Langsung tanpa adanya proses autentikasi dan otorisasi (*backdoor access*).

    c. Menerapkan *session time out* (misalnya *auto logout* atau *session termination*) pada setiap tahapan apabila tidak terdapat aktivitas dari nasabah yang bersangkutan guna menghindari penyalahgunaan oleh pihak lain.

    d. Dalam hal *session time out* pada autentikasi fungsi portofolio dan transaksional yang ditetapkan oleh Anggota Bursa Efek melebihi 5 (lima) menit, maka Anggota Bursa Efek wajib melakukan analisis yang paling kurang mencakup potensi risiko, dampak, kemungkinan terjadinya risiko, serta mitigasi atas risiko tersebut..

    e. Fasilitas *multiple login* tidak diperkenankan.

    f. Memiliki kebijakan atau prosedur operasi standar terkait pengendalian dan pembatasan akses, pengendalian koneksi jaringan, serta ketentuan penggunaan *password*, PIN, geolokasi, dan perangkat terdaftar.

    g. Atas kebijakan atau prosedur operasi standar sebagaimana ketentuan 11 huruf f Pedoman ini, Anggota Bursa Efek wajib memiliki sistem yang dapat memastikan kebijakan atau prosedur operasi standar tersebut terimplementasi

h. Memiliki kebijakan atau prosedur operasi standar terkait registrasi setiap perangkat dan memberikan notifikasi kepada nasabah untuk melakukan konfirmasi atas penggunaan perangkat baru/lain. Pada setiap registrasi dan penggunaan perangkat baru untuk melakukan akses dan transaksi, wajib dilakukan proses verifikasi paling kurang menerapkan MFA dengan menggunakan metode sebagaimana ketentuan 11 huruf a angka 2 Pedoman ini.

i. Memiliki notifikasi kesalahan pada saat login dengan informasi "*Error Message*" secara umum tanpa menyebutkan kesalahan pada *username* atau *password* sehingga nasabah atau pihak lain tidak dapat mengetahui bagian mana yang salah

j. Atas notifikasi sebagaimana ketentuan 11 huruf i Pedoman ini, Anggota Bursa Efek wajib untuk memastikan notifikasi tersebut dapat terimplementasi.

k. Memiliki sistem yang dapat menerapkan batas maksimum kesalahan dalam penginputan PIN atau *password*.

l. Batasan maksimum kesalahan sebagaimana ketentuan 11 huruf k Pedoman ini, mengacu pada Bab 7 huruf B angka 5.d terkait kebijakan account, password, dan audit Pedoman *Remote Trading* yang dikeluarkan oleh Bursa.

m. Anggota Bursa Efek menetapkan parameter keamanan *password* pada Perangkat Keras, Perangkat Lunak, perangkat jaringan, perangkat keamanan jaringan dan aplikasi sesuai kebijakan perusahaan yang mencakup antara lain:

   1) Masa berlaku *password* sebagai fasilitas *enforcement* kepada *user* untuk melakukan perubahan *password* secara berkala;

   2) Kompleksitas *password*;

   3) Panjang minimum *password*;

   4) Sejarah *password*;

12. Pengelolaan Perangkat Lunak

    a. Perangkat lunak yang digunakan wajib berlisensi dan mendapatkan dukungan dari prinsipal.

    b. Melakukan pembaruan (*update* dan *patching*) secara berkala dan sesuai dengan rekomendasi prinsipal atas seluruh perangkat lunak yang digunakan.

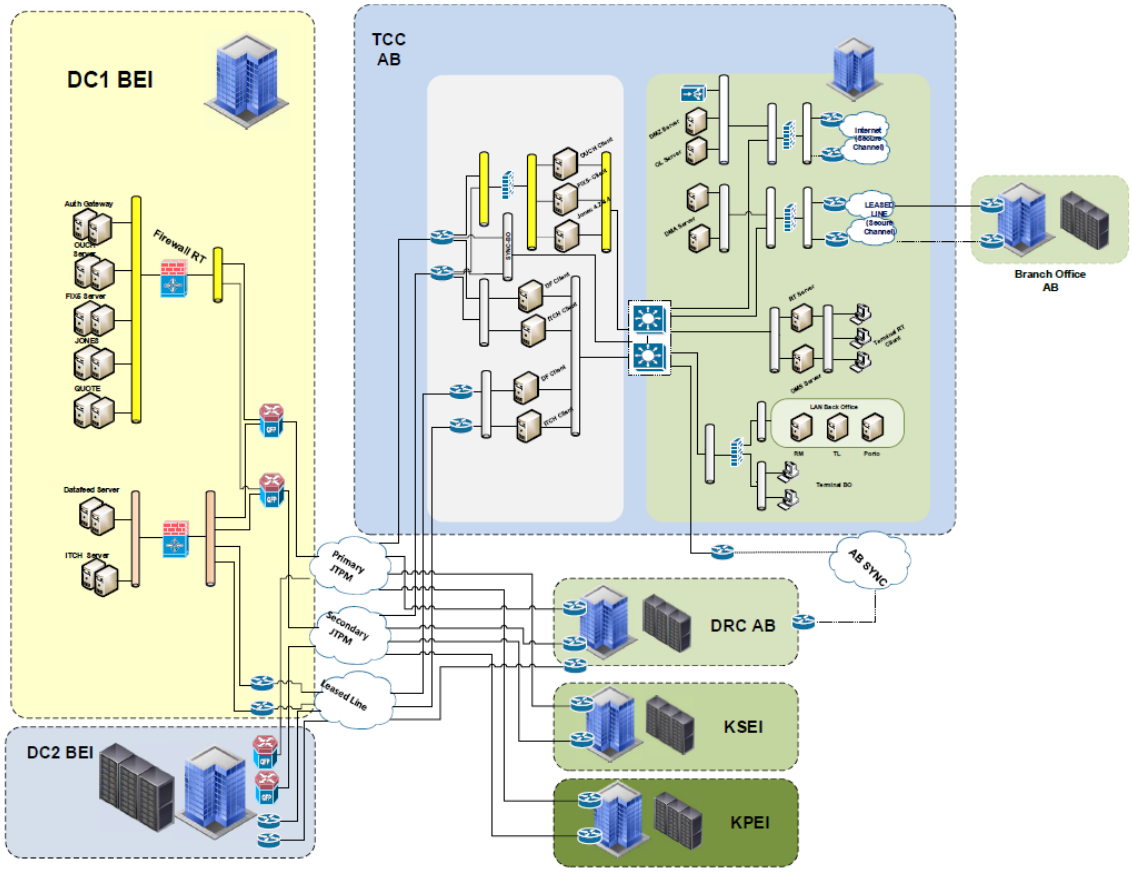
    c. Menerapkan kebijakan pengelolaan versi (*versioning*) atas perangkat lunak yang digunakan.

13. Penempatan Perangkat di dalam Jaringan.

    a. Guna menjaga keamanan dan kinerja sistem, Anggota Bursa Efek harus menggunakan *firewall* tersendiri (*dedicated*) yang dikonfigurasi hanya untuk keperluan penyelenggaraan Fasilitas Pesanan Langsung. Seluruh *port* yang tidak digunakan harus ditutup. Perangkat *firewall* harus masih dalam dukungan (*support*) vendor dan/atau *principal*.

    b. Semua *server* yang digunakan untuk Fasilitas Pesanan Langsung harus ditempatkan di dalam *Demilitarized Zone* (DMZ) sehingga akses yang dilakukan dari luar maupun dari dalam harus melalui *firewall*.

       Gambar jaringan:



Keterangan gambar:

1. Koneksi dari *server back office* ke *server front office* wajib melalui *firewall* dan hanya bisa mengakses *server front office*. Dalam hal *back office* dan *front office* tergabung dalam satu *server* yang sama maka Anggota Bursa Efek wajib memasang *firewall* antara server JATS *Client* dan *server back office*.
2. Koneksi *client* wajib melalui *firewall*.

14. Pengendalian Koneksi Jaringan

    Melakukan pencegahan/pemantauan terhadap penyusupan pada area DMZ yang direkomendasikan dengan menggunakan *Intrusion Prevention System* atau *Intrusion Detection System* (IPS/IDS).

15. Pengendalian Akses terhadap Informasi dan Aplikasi

    Aplikasi Fasilitas Pesanan Langsung harus membatasi akses terhadap informasi maupun terhadap fungsi sesuai dengan otorisasi penggunaan sistem. Dengan demikian informasi maupun fungsi yang tidak boleh diakses tidak dapat dilihat atau dipergunakan.

16. Kebijakan Pengelolaan *Audit Trail* (seperti *password*, PIN, dan *Token*)

    a. Melakukan pengelolaan dalam pembuatan, penggunaan, pengiriman, *reset* dan penghapusan *Audit Trail* untuk menjaga kerahasiaan dan integritas *Audit Trail*. Durasi penyimpanan *Audit Trail* paling kurang 5 (lima) tahun.

    b. Data rahasia seperti PIN /*password* tidak boleh dicatat di *Audit Trail*.

17. Kebijakan Penggunaan Kriptografi

    Data yang bersifat sensitif atau bersifat rahasia harus tersimpan dalam keadaan terenkripsi, sebagai contoh data yang menyangkut identitas nasabah atau PIN / *password*.

18. Penghindaran Kebocoran Aplikasi

    Aplikasi tidak menggunakan *cookies* atau *file* sementara yang dapat dimanfaatkan untuk menyimpan data yang bersifat rahasia seperti *password*.

19. Pengendalian terhadap Kerawanan Teknis

    a. Anggota Bursa Efek wajib melakukan *penetration test* terhadap sistem Fasilitas Pesanan Langsung Anggota Bursa Efek sebelum sistem *Live*. Selain itu Anggota Bursa Efek wajib melaksanakan evaluasi keamanan sistem dengan melakukan *vulnerability assessment* atau *penetration test* secara berkala dengan periode paling kurang 1 (satu) tahun sekali atau setiap kali dilakukan atau terdapat perubahan aplikasi pada area *main site* dan DR *site*.

    b. Anggota Bursa Efek wajib menyampaikan laporan hasil *vulnerability assessment* atau *penetration test* berkala dengan periode paling kurang 1 (satu) tahun sekali pada area *main site* dan DR *site* ke Bursa.

    c. Ketentuan dalam melakukan penetration test adalah sebagai berikut:

        1) Metode *penetration test* yang dilakukan adalah *gray box*.
        2) Area *penetration test* dilakukan dari eksternal atau internet ke sistem Fasilitas Pesanan Langsung Anggota Bursa Efek.
        3) *Penetration test* dilakukan sebelum sistem *Live*.
        4) *Penetration test* dapat dilakukan oleh vendor yang ditunjuk oleh Anggota Bursa Efek atau internal Anggota Bursa Efek yang memiliki kompetensi dibuktikan dengan sertifikasi LPT (*Licensed Penetration Tester*) atau sertifikasi setara yang masih berlaku.
        5) Apabila dari hasil *penetration test* ditemukan celah atau potensi kerawanan yang bersifat *critical*, *high*, dan/atau *medium*, maka Anggota Bursa Efek wajib menindaklanjuti dengan menutup celah atau potensi kerawanan tersebut dan melakukan *penetration test* lanjutan sampai tidak ditemukannya celah atau potensi kerawanan yang bersifat *critical*, *high*, dan/atau *medium*.

    d. Ketentuan dalam pelaksanaan *vulnerability assessment* adalah sebagai berikut:

        1) *Vulnerability assessor* dapat berasal dari internal/eksternal Perusahaan yang memiliki sertifikasi CEH (*Certified Ethical Hacker*) atau setara yang masih berlaku.
        2) Apabila dari hasil *vulnerability assessment* ditemukan celah atau potensi kerawanan yang bersifat *critical*, *high*, dan/atau *medium*, maka Anggota Bursa Efek wajib menindaklanjuti dengan menutup celah atau potensi kerawanan tersebut dan melakukan *vulnerability assessment* lanjutan sampai tidak ditemukannya celah atau potensi kerawanan yang bersifat *critical*, *high*, dan/atau *medium*.

    e. Aspek-aspek yang perlu diuji di dalam pelaksanaan *vulnerability assessment* dan *penetration test* antara lain perimeter jaringan, *operating system*, *web server*, *database server* serta *server-server* penunjang lainnya, perangkat jaringan dan aplikasi.

    f. Menerapkan *patch* secara berkelanjutan terhadap *Common Vulnerabilities and Exposure* (CVE) termasuk *security* lainnya pada komponen-komponen sistem.

    g. Proses *patching* sebagaimana dimaksud ketentuan 19 huruf f Pedoman ini, meliputi:

1) Patching pada aplikasi baik di sisi Anggota Bursa Efek maupun Nasabah, *operating system*, *server*, database, perangkat jaringan, perangkat keamanan dan perangkat komunikasi.

2) Melakukan pengujian pasca penerapan patch (*post-patching testing*) untuk memastikan sistem berfungsi dengan baik.

h. Wajib melakukan pemberian kepedulian (*awareness*) dan/atau literasi kepada Nasabah:

1) mengenai keamanan sistem dan risiko dalam penggunaan sistem Fasilitas Pesanan Langsung.

2) agar nasabah secara rutin melakukan pengecekan laporan aktivitas transaksi untuk mendeteksi adanya mutasi transaksi yang dilakukan pihak lain selain Nasabah

i. Memiliki fungsi penghentian penyampaian pesanan apabila terdapat *erroneous* pada Fasilitas Pesanan Langsung.

20. Anggota Bursa Efek wajib untuk melaporkan setiap permasalahan sistem operasional yang dimiliki termasuk namun tidak terbatas pada sistem perdagangan (seperti: *Brokerage Office System*, dan/atau *Business Continuity Plan) untuk memperdagangkan* Efek Bersifat Ekuitas beserta produk turunannya dan/atau izin lain yang dimiliki oleh Anggota Bursa Efek.

IV. KETENTUAN TAMBAHAN BAGI ANGGOTA BURSA EFEK YANG MENYEDIAKAN FASILITAS PESANAN LANGSUNG DENGAN MELAKUKAN KERJASAMA LAYANAN ATAU MENGGUNAKAN JASA PIHAK LAIN

Selain memenuhi ketentuan terkait konsep utama keamanan sistem sebagaimana dimaksud dalam ketentuan III. Pedoman ini, Anggota Bursa Efek yang akan menyediakan Fasilitas Pesanan Langsung dengan melakukan kerjasama layanan atau menggunakan jasa pihak lain juga wajib memenuhi persyaratan teknis terkait pemanfaatan sistem yang disediakan pihak lain, yang paling kurang meliputi hal-hal sebagai berikut:

1. Memastikan bahwa aplikasi yang disediakan pihak lain telah memenuhi ketentuan perundang-undangan terkait sistem dan/atau transaksi elektronik yang berlaku, antara lain:

a. Undang-Undang Nomor 11 Tahun 2008 tentang Informasi dan Transaksi Elektronik, sebagaimana telah diubah dengan Undang-Undang Nomor 19 tahun 2016 tentang Perubahan atas Undang-Undang Nomor 11 Tahun 2008 tentang Informasi dan Transaksi Elektronik;

b. Peraturan Pemerintah Nomor 71 tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik; dan

c. Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi.

2. Memiliki perjanjian tertulis dengan pihak lain yang paling kurang mencakup:

a. Nama pihak;

b. Ruang lingkup, syarat dan kondisi fungsi Anggota Bursa Efek yang pelaksanaannya diserahkan kepada pihak lain;

c. Kriteria evaluasi kinerja pihak lain untuk memastikan bahwa pihak lain tersebut memelihara tingkat keamanan sistem dan tingkat layanan;

d. Tanggung jawab Anggota Bursa Efek dan pihak lain, serta pengawasan atas pelaksanaan tanggung jawab tersebut;

e. Standar layanan jasa, dan mekanisme untuk memastikan bahwa standar tersebut dapat dipenuhi setiap saat;

f. Kerahasiaan dan keamanan informasi;

g. Tanggung jawab terkait dengan keamanan sistem teknologi informasi;

h. Pelaporan secara berkala oleh pihak lain kepada Anggota Bursa Efek;

i. Pertanggungjawaban dari pihak lain kepada Anggota Bursa Efek atas pelayanan yang tidak memuaskan atau pelanggaran lainnya atas perjanjian;

j. Jaminan atas kualitas layanan jasa dan ganti rugi;

k. Kewajiban pihak lain setiap saat jika diminta, untuk menyediakan setiap catatan, informasi dan/atau bantuan berkaitan dengan sistem yang disediakan oleh pihak lain jika diminta oleh Anggota Bursa Efek, Bursa, Otoritas Jasa Keuangan dan/atau pihak lain yang ditunjuk oleh Otoritas Jasa Keuangan;

l. Larangan bagi pihak lain untuk mengalihkan tanggung jawab ke pihak ketiga (sub kontrak) atas layanan yang diberikan kepada Anggota Bursa Efek;

m. Ketentuan-ketentuan tentang keberlangsungan fungsi Anggota Bursa Efek dalam hal pihak lain mengalami kondisi darurat sehingga tidak dapat menjalankan fungsinya;

n. Sanksi apabila pihak lain tidak memenuhi perjanjian *Service Level Agreement* (SLA);

o. Pengakhiran perjanjian, yang meliputi antara lain transfer informasi dan langkah-langkah pemutusan perjanjian serta prosedur transisi;

p. Mekanisme untuk menyelesaikan perselisihan yang timbul antara Anggota Bursa Efek dengan pihak lain.

3. Memiliki *Non-Disclosure Agreement* (NDA) dengan pihak lain yang paling kurang memuat:

   a. Pengendalian penuh terhadap informasi yang berada di pihak lain;

   b. Pembatasan informasi yang diperlukan saja untuk penyampaian pesanan menggunakan pihak lain;

   c. Tidak ada pemanfaatan informasi oleh pihak lain tanpa persetujuan dari nasabah Anggota Bursa Efek.

4. Memastikan bahwa pihak lain memiliki petugas Teknologi Informasi yang masing-masing menjalankan paling kurang fungsi *helpdesk* dan *monitoring*, fungsi operasional dan dukungan teknis, dan fungsi pengembangan;

5. Memastikan bahwa pihak lain memiliki prosedur paling kurang meliputi:

   a. Prosedur evaluasi secara berkala termasuk analisis risiko terhadap fasilitas dan pelaksanaan sistem Fasilitas Pesanan Langsung yang diselenggarakan;

   b. Prosedur penanganan gangguan.

6. Memastikan adanya:

   a. mekanisme autentikasi untuk memastikan bahwa transaksi tersebut dilakukan oleh nasabah dari Anggota Bursa Efek.

   b. mekanisme validasi untuk penyampaian pesanan.

   c. mekanisme konfirmasi atas pesanan.

7. Memastikan bahwa nasabah mengetahui risiko dalam penggunaan aplikasi dari pihak lain.
8. Memastikan pihak lain melakukan *vulnerability assessment* dan *penetration test* sebelum sistem digunakan di area produksi dan melakukan *vulnerability assessment* secara berkala dengan periode paling kurang 1 (satu) tahun sekali.
9. Sistem Fasilitas Pesanan Langsung paling kurang menampilkan informasi notasi khusus (jika ada) dan memberikan tampilan khusus atas saham pada Papan Akselerasi sesuai dengan Pedoman *Brokerage Office System* (BOFIS).
10. Memiliki fungsi penghentian penyampaian pesanan apabila terdapat *erroneous* pada sistem yang disediakan oleh pihak lain.
11. Memastikan bahwa data dari sistem yang disediakan pihak lain berada di wilayah Republik Indonesia.

V. KETENTUAN TEKNIS BAGI ANGGOTA BURSA EFEK YANG MENERAPKAN *AUTOMATED ORDERING*

Anggota Bursa Efek yang akan menyediakan *Automated Ordering* wajib memenuhi persyaratan teknis yang paling kurang meliputi:

1. Memiliki sistem kontrol risiko atau *monitoring* operasional *Automated Ordering* yang dapat melakukan pengawasan secara *real time* atas order dan transaksi dan memiliki fitur untuk *alert*, *rejection system*, dan *interruption system* dari kondisi anomali atau *erroneous* sesuai batasan yang telah ditentukan sesuai dengan *risk appetite* Anggota Bursa Efek.
2. Memiliki sistem *monitoring* yang dapat menampilkan *alert* terkait adanya *looping order* secara terus menerus.
3. Memenuhi konfigurasi infrastruktur dan *network* yang dipersyaratkan Bursa, khususnya untuk *security*.
4. Memiliki sistem *logging* untuk audit trail dan sistem *reproduce problem*.
5. Memiliki *order management* yang dapat mengontrol semua *order* yang berasal dari sistem *Automated Ordering*, antara lain:
   a. *volume* (lot) terkecil setiap order ketika *Automated Ordering* melakukan *split order*.
   b. jumlah *repeat order* setiap detik ketika *Automated Ordering* melakukan *split order*.
   c. evaluasi rasio *order-to-trade* per bulan.
   d. evaluasi rasio *order-to-amend* per bulan.
   e. evaluasi rasio *order-to-withdraw* per bulan.
6. Sistem *order management* tidak memiliki fitur atau fungsi *order* yang dapat melakukan *amend* atau *withdraw order* dalam detik yang sama dengan waktu *order*.
7. Sistem dapat mengirimkan *flag order Automated Ordering* sesuai dengan spesifikasi teknis FIX5 atau OUCH.
8. Membuat skenario pengujian atas strategi *Automated Ordering* yang dimiliki termasuk skenario pengujian *negative test*.
9. Melakukan pengujian *Automated Ordering* di area *development* dan *production* Bursa menggunakan skenario yang telah dibuat sesuai poin 8 dan skenario *mock trading* dari Bursa.
10. Memiliki fungsi *panic button* yang dapat menghentikan pengiriman *order* jika terjadi kesalahan pada *Automated Ordering*, meliputi kemampuan sebagai berikut:
    a. penghentian sementara proses pembentukan *order*;
    b. penghentian seluruh proses pengiriman *order*;

c. penghentian algoritma pada *automated ordering* yang dimiliki; dan/atau
d. melakukan pengelolaan *outstanding order*.